

개선 요구

1. 제 목 : 개인정보처리시스템 접근권한 관리 불철저
2. 소관부점 : 정보시스템실
3. 내 용 :

가. 업무개요

정보시스템실은 「업무분장세칙」 제13조 제1항 및 제3항에 따라 정보 시스템 개발·관리 운영 업무와 정보보안 및 정보보호 업무를 수행하고 있다.

나. 관계 법령·내규 및 판단 기준

정부의 2022. 7. 14. 「공공부문 개인정보 유출 방지대책」에 따르면 개인정보처리시스템(이하 “업무시스템”이라 한다) 보호대책 강화를 위하여 접근권한의 경우 인사정보와 연동하여 정보 불일치 시 권한을 자동 말소하도록 하고 있고

2021. 7. 5. 금융감독원에서 공사를 대상으로 실시한 「개인신용정보 활동·관리 실태 등에 대한 점검」에 따르면 업무시스템의 접근권한은 인사이동 발생 시 지체 없이 접근권한을 변경 또는 말소하도록 하고 있으며, 업무시스템의 접속이력이 없거나 장기간 접속하지 않는 미사용자의 권한은 회수하도록 하고 있다.

또한, 「개인정보 보호법」 제29조 및 같은 법 시행령 제30조에 따르면 업무시스템의 권한관리 등 안전조치의무를 소홀히 할 경우 과태료¹⁾ 부과 대상이며, 2023. 3. 9. 개인정보보호위원회는 경기교통공사 등 10개 기관에 업무시스템의 권한관리 및 접속기록 관리 미흡과 관련하여 과태료를 부과한 사실이 있다.

한편, 「정보화업무요강」 제31조 제2항 및 제32조 제1항 및 제3항에 따르면 정보시스템실장은 업무시스템 보호 및 사고방지를 위하여 업무시스템 자원의 사용 및 접근을 통제할 수 있고, 접근 통제 방법 및 절차는 정보시스템실장이 정하여 시행한다고 되어 있다.

따라서, 정보시스템실은 개인정보 유출 방지 등 업무시스템 보호를 위하여 인사이동 등의 사유로 업무가 변경될 경우 업무시스템의 접근권한을 즉시 회수하고, 장기간 미사용한 사용자의 권한은 미사용 기간 초과 시 즉시 회수될 수 있도록 권한관리 방안을 마련하여야 한다.

1) 개인정보 보호법 시행령 제63조(과태료의 부과기준)에 따라 안전성 위반의 경우 1회 600만 원, 2회 1,200만 원, 3회 이상 2,400만 원의 과태료가 부과됨

다. 감사결과 확인된 문제점

그런데 감사대상기간 동안 업무시스템 전반의 사용자 접근권한 부여 및 회수 현황 등을 점검²⁾한 결과

경영지원실 ◇◇◇담당 직원의 경우 2023. 2. 1. 인사이동으로 채권 업무를 수행하고 있지 않음에도 2013. 2. 5. 부여한 한마음금융, 희망모아 시스템의 접근권한이 감사일 현재까지 회수되지 않았으며, 2023. 2. 20. 업무 인계인수 등의 사유로 일시적으로 부여된 채권관리시스템의 접속 권한 또한 회수되지 않은 사실이 확인되었다.

또한, 인재경영실 소속 직원의 경우 2023. 5. 10. 교육과전으로 현재 공공개발업무를 수행하고 있지 않고, 업무시스템 최종 접속일자가 2021. 10. 13.로 장기 미사용에 해당하여 최소 3개월이 지난 2022. 1. 11. 접속권한을 회수하였어야 하는데도 감사일 현재까지 권한 회수 조치가 이루어지지 않는 등

[표 31]과 같이 인사이동 등의 사유로 업무가 변경 되었으나 권한이 회수 되지 않은 10개의 업무시스템과 업무시스템을 장기 미사용 중인 데도 권한이 회수되지 않은 9개³⁾의 시스템이 확인되었다.

2) K-Wings(그룹웨어)는 감사대상기간 중 장기 미사용자에 대한 계정 정지 기능을 추가하여, 점검대상에서 제외함

3) 국유재산관리, 국민행복기금, 소액대출, 한마음금융, 희망모아, 조세채권정리, 체납국세 위탁징수, 국가연체채권 위탁징수, 공공개발

[표 31] 업무시스템 권한 부여 및 관리 현황

(단위 : 건)

순번	업무시스템	권한 분류				비 고
		계	정당 부여	회수대상		
				업무외*	장기 미사용**	
합계		4,860	4,044	334	482	
1	공사채권	1,087	910	177	-	권한관리 기능 개선확인(차세대시스템)
2	새출발기금	332	326	6	-	인사정보 연동하여 권한관리 필요
3	국유재산관리	1,098	883	-	215	장기미사용 관리 필요
4	국민행복기금	705	632	4	69	장기미사용 관리 필요
5	소액대출	182	86	-	96	장기미사용 관리 필요
6	한마음금융	230	226	4	확인불가	접속기록 및 장기미사용 관리 필요
7	희망모아	234	228	6	확인불가	접속기록 및 장기미사용 관리 필요
8	조세채권정리	338	280	5	53	장기미사용 관리 필요
9	체납국세	142	126	16	확인불가	접속기록 및 장기미사용 관리 필요
10	국가연체채권	173	86	87	확인불가	접속기록 및 장기미사용 관리 필요
11	온비드	72	72	-	-	관리 적정(특정부서 사용)
12	공공개발	236	161	26	49	장기미사용 관리 필요
13	기업자산인수	23	20	3	-	관리 적정(특정부서 사용)
14	캠코동산금융	8	8	-	-	관리 적정(특정부서 사용)

* 인사이동으로 인하여 수행업무가 바뀐 경우

** 최종 접속일자로부터 90일이 경과하도록 업무시스템에 접속하지 않은 경우

따라서, 업무시스템의 안전조치 강화를 위하여 인사정보와 연동되어 관리되지 않는 업무시스템에 대하여 인사정보와 연동하여 자동으로 권한 회수가 이루어질 수 있도록 하고, 90일 이상4) 업무시스템에 접속하지 않는 장기 미사용 권한의 경우 다음 날 자동 회수되도록 전산기능을 마련할 필요가 있다.

[소관부점 의견] 정보시스템실은 감사결과를 수용하면서 고객 개인정보 보호를 위해 접근권한 회수 기능을 마련하겠다고 하였다.

4) 공사채권 업무시스템의 경우 90일 이상 장기미사용자의 경우 익일 권한이 회수되도록 구현되어 있음

4. 조치할 사항

정보시스템실장은 업무시스템의 접근권한 관리가 철저하게 이루어질 수 있도록 인사정보와 연동하여 접속권한이 회수될 수 있도록 하고, 90일 이상 장기 미사용 권한이 자동으로 회수될 수 있도록 전산을 개선하시기 바랍니다.(개선)